

Báo cáo

Nâng cao 1. Reverse Engineering với x64dbg/IDA

Mẫu 1

MỤC LỤC

1. Phân tích tĩnh với IDA.....	3
1.1 Thông tin về mẫu.....	3
1.2 Nhận định.....	5
2. Phân tích động.....	6
3. Kết luận.....	9

1. Phân tích tĩnh với IDA

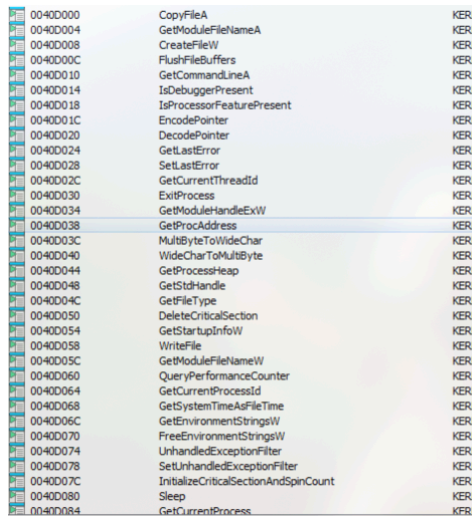
1.1 Thông tin về mẫu

a. Tên file: FolderStartup.exe.

b. Kiểu file: PE32 executable for MS Windows 6.00 (console), Intel i386, 5 sections

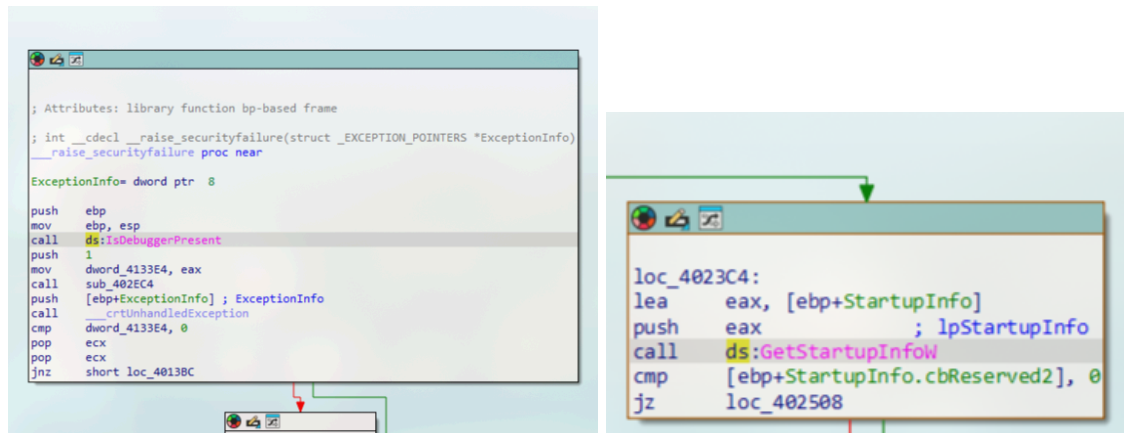
c. Các API đáng ngờ

Dựa vào mục Imports của IDA, có thể thấy chương trình đã nạp các API từ 3 thư viện kernel32.dll, user32.dll, shell32.dll. Các API đáng ngờ: GetStartupInfoW, SHGetFolderPathA, CopyFileA, CreateFileW, WriteFile, IsDebuggerPresent.



00400000	CopyFileA	KERI
00400004	GetModuleFileNameA	KERI
00400008	CreateFileW	KERI
0040000C	FlushFileBuffers	KERI
00400010	GetCommandLineA	KERI
00400014	IsDebuggerPresent	KERI
00400018	IsProcessorFeaturePresent	KERI
0040001C	EncodePointer	KERI
00400020	DecodePointer	KERI
00400024	GetLastError	KERI
00400028	SetLastError	KERI
0040002C	GetCurrentThreadId	KERI
00400030	ExitProcess	KERI
00400034	GetModuleHandleExW	KERI
00400038	GetProcAddress	KERI
0040003C	MultiByteToWideChar	KERI
00400040	WideCharToMultiByte	KERI
00400044	GetProcessHeap	KERI
00400048	GetStdHandle	KERI
0040004C	GetFileType	KERI
00400050	DeleteCriticalSection	KERI
00400054	GetStartupInfoW	KERI
00400058	WriteFile	KERI
0040005C	GetModuleFileNameW	KERI
00400060	QueryPerformanceCounter	KERI
00400064	GetCurrentProcessId	KERI
00400068	GetSystemTimeAsFileTime	KERI
0040006C	FreeEnvironmentStringsW	KERI
00400070	FreeEnvironmentStringsW	KERI
00400074	UnhandledExceptionFilter	KERI
00400078	SetUnhandledExceptionFilter	KERI
0040007C	InitializeCriticalSectionAndSpinCount	KERI
00400080	Sleep	KERI
00400084	GetCurrentProcess	KERI

Các API IsDebuggerPresent, GetStartupInfoW không được gọi từ main nên có thể bỏ qua.



Ngoài ra có LoadLibraryExW và GetProcAddress thường được dùng để nạp thêm API từ nguồn khác ([tham khảo](#)). Ở đây, Chúng được dùng để gọi MessageBoxW.

```

push     esi             ; dwFlags
push     esi             ; hFile
push     offset LibFileName ; "USER32.DLL"
call     ds:LoadLibraryExW
mov      edi, eax
test     edi, edi
jz       loc_406729

loc_4065D6:
push     offset aMessageboxw ; "MessageBoxW"
push     edi             ; hModule
call     ds:GetProcAddress
test     eax, eax
jz       loc_406729

```

d. Strings đáng ngờ (tính năng View -> Open subviews -> Strings)

"C:\\Users\\Admin\\Documents\\Visual Studio

2013\\Projects\\Persistence\\FolderStartup\\Release\\FolderStartup.pdb";

"DONE Folder Startup ><";

79	.rdata:0041...	00000007	C	1#QNAN
79	.rdata:0041...	0000000E	C	FolderStartup
79	.rdata:0041...	00000017	C	DONE Folder Startup ><
79	.rdata:0041...	00000069	C - U...	C:\\Users\\Admin\\Documents\\Visual Studio 2013\\Projects\\Persistence\\FolderStartup\\Release\\FolderStartup.pdb
79	.rdata:0041...	0000000A	C	CopyFileA
79	.rdata:0041...	00000013	C	GetModuleFileNameA
79	.rdata:0041...	0000000D	C	KERNEL32.dll
79	.rdata:0041...	0000000C	C	MessageBoxA
79	.rdata:0041...	0000000B	C	USER32.dll
79	.rdata:0041...	00000011	C	SHGetFolderPathA
79	.rdata:0041...	0000000C	C	SHELL32.dll

e. Dịch ngược

Mã giả của hàm main:

```

1 int cdecl main(int argc, const char **argv, const char **envp)
2 {
3     char *v3; // eax
4     CHAR NewFileName[260]; // [esp+0h] [ebp-310h] BYREF
5     CHAR pszPath[260]; // [esp+104h] [ebp-20Ch] BYREF
6     CHAR Filename[260]; // [esp+208h] [ebp-108h] BYREF
7
8     GetModuleFileNameA(0, Filename, 0x104u);
9     SHGetFolderPathA(0, 7, 0, 0, pszPath);
10    v3 = strrchr(Filename, 92);
11    sprintf_s(NewFileName, 0x104u, "%s%s", pszPath, v3);
12    CopyFileA(Filename, NewFileName, 0);
13    MessageBoxA(0, "DONE Folder Startup ><", "FolderStartup", 0);
14    return 0;
15 }

```

Dòng 8: GetModuleFileNameA với tham số thứ nhất = 0 (NULL) -> chương trình trích xuất path của file hiện tại. Tham số thứ 2 là *Filename* - lưu path.

Dòng 9, từ hàm [SHGetFolderPathA](#), có thể thấy biến pszPath chứa path đích mà hàm này muốn lấy. Tham số thứ 2 của hàm (csidl) có giá trị = 7. Dựa vào bảng giá trị của [CSIDL](#), path đích muốn lấy chính là `CSIDL_COMMON_ALTSTARTUP`.

Dòng 10, với hàm [strchr](#):

- *Filename* đang lưu giá trị path được trích xuất ở dòng 8. Path có dạng `C\...\<>.exe`
- 92: tương ứng ký tự ASCII '\'

Vậy kết quả dòng 10 là v3 trở đến vị trí cuối cùng xuất hiện '\' trong *Filename*, tức `"\<>.exe"`.

Dòng 11, với hàm [sprintf_s](#): viết chuỗi kết hợp bởi pszPath và v3 vào *NewFileName*. Vậy *NewFileName* chứa `\path\đích\<>.exe`.

Dòng 12: copy file tại địa điểm cũ (tại *Filename*) đến địa điểm mới, tại *NewFileName*.

1.2 Nhận định

Từ các API và strings đáng ngờ, kết hợp với dịch ngược, đây là chương trình sử dụng kỹ thuật persistence thông qua *Startup folder*.

2. Phân tích động

Vì chương trình đã cho thuộc kiến trúc 32-bit, sử dụng x32dbg.

Từ địa chỉ của .text trong mục Memory Map, di chuyển đến địa chỉ 00AC1000 và xem mã assembly.

The screenshot shows the x32dbg interface. The Memory Map window displays the following memory layout:

Address	Size	Module	Section
00AC0000	00001000	folderstartup.exe	
00AC1000	0000C000		".text"
00ACD000	00005000		".rdata"
00AD2000	00003000		".data"
00AD5000	00001000		".rsr"
00AD6000	00001000		".reloc"
00AE0000	00059000		
00B39000	013A7000	Reserved (00AE0000)	
73290000	00008000		
732A0000	0005C000		
73300000	0003F000		
74680000	00001000	cryptbase.dll	
74681000	00008000		".text"

The Disassembly window shows the following assembly code:

```
00AC1000 55          push ebp
00AC1001 8BEC       mov ebp,esp
00AC1003 81EC 10030000 sub esp,310
00AC1009 A1 0020AD00 mov eax,dword ptr ds:[AD2000]
00AC100E 33C5       xor eax,ebp
00AC1010 8945 FC    mov dword ptr ss:[ebp-4],eax
00AC1013 68 04010000 push 104
00AC1018 8D85 F8FEFFFF lea eax,dword ptr ss:[ebp-108]
00AC101E 50         push eax
00AC101F 6A 00      push 0
00AC1021 FF15 04D0AC00 call dword ptr ds:[<&GetModuleFileNameA]
00AC1027 8D85 F4DFFFFF lea eax,dword ptr ss:[ebp-20C]
00AC102D 50         push eax
00AC102E 6A 00      push 0
00AC1030 6A 00      push 0
00AC1032 6A 07      push 7
00AC1034 6A 00      push 0
00AC1036 FF15 F8D0AC00 call dword ptr ds:[<&SHGetFolderPathA]
00AC103C 8D85 F8FEFFFF lea eax,dword ptr ss:[ebp-108]
```

Thực hiện đặt breakpoint tại các API: GetModuleFileName, SHGetFolderPath, CopyFile.

Type	Address	Module/Label/Exception	State	Disassembly
Software	758B731C	<shell32.dll.SHGetFolderPathA>	Enabled	mov edi,edi
	76611491	<kernel32.dll.GetModuleFileNameA>	Enabled	mov edi,edi
	76635F0F	<kernel32.dll.CopyFileA>	Enabled	mov edi,edi

Đầu tiên, đặt breakpoint tại GetModuleFileNameA và cho chương trình chạy đến breakpoint

The screenshot shows the x32dbg Disassembly window. The EIP register is set to 76611491, which is the address of the GetModuleFileNameA breakpoint. The assembly code is as follows:

```
EIP 76611491 8BFF       mov edi,edi
76611493 55         push ebp
76611494 8BEC       mov ebp,esp
76611496 5D         pop ebp
76611497 EB 05      jmp <JMP.&GetModuleFileNameA>
76611499 90         nop
7661149A 90         nop
7661149B 90         nop
7661149C 90         nop
7661149D 90         nop
7661149E FF25 280B6176 jmp dword ptr ds:[<&GetModuleFileNameA>] JMP.&GetModuleFileNameA
766114A4 90         nop
766114A5 90         nop
766114A6 90         nop
```

Thông tin stack:

The screenshot shows the x32dbg Disassembly window. The stack is shown as follows:

```
0039F9AC 00F91027 return to folderstartup.00F91027 from ???
0039F980 00000000
0039F984 0039F9C4
0039F988 00000104
0039F98C 00000000
0039F9C0 0014A310 "windows_tracing_logfile=C:\\BVTBin\\Tests\\installpackage\\csilogfile.log"
```

Khi theo dõi trong Disassembler tại địa chỉ 0039F9AC (return address trên), có được:

00F91021	FF15 04D0F900	call dword ptr ds:[<&GetModuleFileNameA]
00F91027	8D85 F4FDFFFF	lea eax,dword ptr ss:[ebp-20C]
00F9102D	50	push eax
00F9102E	6A 00	push 0
00F91030	6A 00	push 0
00F91032	6A 07	push 7
00F91034	6A 00	push 0
00F91036	FF15 F8D0F900	call dword ptr ds:[<&SHGetFolderPathA]

Đây chính là logic của dòng code chứa GetModuleFileNameA trong mã giả.

Quay lại quan sát các tham số trong stack, tham số thứ 2 của hàm (Filename) là 1 con trỏ đến 1 buffer. Để quan sát dữ liệu mà con trỏ này nhận vào, chọn địa chỉ của tham số này và chọn "Follow DWORD in Dump". Có thể thấy hiện tại vùng nhớ này đang chưa chứa dữ liệu.

Address	Hex	ASCII
01243530	00 00 00 00	
01243540	00 00 00 00	
01243550	00 00 00 00	
01243560	00 00 00 00	
01243570	00 00 00 00	
01243580	00 00 00 00	
01243590	00 00 00 00	
012435A0	00 00 00 00	
012435B0	00 00 00 00	
012435C0	00 00 00 00	
012435D0	00 00 00 00	
012435E0	00 00 00 00	
012435F0	00 00 00 00	
01243600	00 00 00 00	
01243610	00 00 00 00	
01243620	00 00 00 00	

Tiếp theo, chọn "Execute til Return". Chương trình sẽ chạy đến khi hàm GetModuleFileNameA trả về. Lần này, trong dump đã xuất hiện giá trị chứa trong buffer của Filename, là path của chính chương trình.

Address	Hex	ASCII
01243530	43 3A 5C 55 73 65 72 73 5C 74 72 61 6E 67 5C 44	C:\Users\trang\Down
01243540	6F 77 6E 6C 6F 61 64 73 5C 33 2E 50 65 72 73 69	ownloads\3.Persi
01243550	73 74 65 6E 63 65 5C 46 6F 6C 64 65 72 53 74 61	stence\FolderSta
01243560	72 74 75 70 2E 65 78 65 00 00 00 00 00 00 00 00	rtup.exe.....
01243570	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00	
01243580	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00	
01243590	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00	
012435A0	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00	

Chuyển sang API SHGetFolderPathA. Cho chương trình chạy tới breakpoint này.

758B731C	8BFF	mov edi,edi	SHGetFolderPathA
758B731E	55	push ebp	
758B731F	8BEC	mov ebp,esp	
758B7321	81EC 0C020000	sub esp,20C	
758B7327	A1 ECD8675	mov eax,dword ptr ds:[75B60FEC]	eax:L"me1\\Users\\trang\\Downloads\\3.Persistence\\FolderStartup.exe"
758B732C	33C5	xor eax,ebp	
758B732E	8945 FC	mov dword ptr ss:[ebp-4],eax	

Các lệnh của hàm (địa chỉ 000C103C)

000C1036	FF15 F8D0C000	call dword ptr ds:[<&SHGetFolderPathA]	
000C103C	8D85 F8FEFFFF	lea eax,dword ptr ss:[ebp-108]	
000C1042	6A 5C	push 5C	eax:L"me1\\Users\\trang\\Downloads\\3.Persistence\\FolderStartup.exe"
000C1044	50	push eax	

Thực hiện tương tự, sau khi cho chương trình Execute till return, quan sát giá trị của các tham số của hàm trong stack.

FA8C	000C103C	return to folderstartup.000C103C from ???
FA90	00000000	
FA94	00000007	
FA98	00000000	
FA9C	00000000	
FAA0	0049FBAS	"C:\\Users\\trang\\AppData\\Roaming\\Microsoft\\Windows\\Start Menu\\Programs\\Startup"
FAA4	00000000	

Tham số thứ 2 (csidl) có giá trị 7 - chính là giá trị của [CSIDL_COMMON_ALTSTARTUP](#).

Tham số thứ 5 (pszPath) là 1 con trỏ đến 1 buffer lưu giữ chuỗi path đích. Địa chỉ của pszPath là 0049FBA8. Trong dump, giá trị của pszPath chính là folder Startup của user.

0049FBA8	43 3A 5C 55	73 65 72 73	5C 74 72 61	6E 67 5C 41	C:\Users\trang\A
0049FBB8	70 70 44 61	74 61 5C 52	6F 61 6D 69	6E 67 5C 4D	ppData\Roaming\M
0049FBC8	69 63 72 6F	73 6F 66 74	5C 57 69 6E	64 6F 77 73	icrosoft\windows
0049FBD8	5C 53 74 61	72 74 20 4D	65 6E 75 5C	50 72 6F 67	\Start Menu\Prog
0049FBE8	72 61 6D 73	5C 53 74 61	72 74 75 70	00 00 5C 00	rams\Startup..\.

Chuyển sang API CopyFileA

002D1081	6A 00	push 0	
002D1083	68 DC0D2E00	push folderstartup.2E0DDC	2E0DDC:"FolderStartup"
002D1088	68 EC0D2E00	push folderstartup.2E0DEC	2E0DEC:"DONE Folder Startup ><"
002D108D	6A 00	push 0	

Các tham số trong stack sau khi hàm thực thi:

Default (stdcall)			5	Unlock
1:	[esp+4]	002FFC20 "C:\\Users\\trang\\Downloads\\3.Persistence\\FolderStartup.exe"		
2:	[esp+8]	002FFA18 "C:\\Users\\trang\\AppData\\Roaming\\Microsoft\\windows\\Start Menu\\Programs\\Startup\\FolderStartup.exe"		
3:	[esp+C]	00000000		
4:	[esp+10]	555C3A43		
5:	[esp+14]	73726573		
002FFA08	013A1081	return to folderstartup.013A1081 from ???		
002FFA0C	002FFC20	"C:\\Users\\trang\\Downloads\\3.Persistence\\FolderStartup.exe"		
002FFA10	002FFA18	"C:\\Users\\trang\\AppData\\Roaming\\Microsoft\\windows\\Start Menu\\Programs\\Startup\\FolderStartup.exe"		
002FFA14	00000000			
002FFA18	555C3A43			

Vậy ở API này, chương trình copy chính nó từ folder gốc đến folder Startup.

3. Kết luận

Tóm tắt hành vi:

1. Truy xuất đường dẫn tuyệt đối của chính file thực thi đang chạy thông qua API `GetModuleFileNameA`.
2. Truy vấn đường dẫn của thư mục Startup của hệ thống bằng API `SHGetFolderPathA` với tham số đầu vào được xác định là `CSIDL_COMMON_ALTSTARTUP`.
3. Trích xuất tên file hiện tại từ đường dẫn gốc và sử dụng hàm `sprintf_s` để ghép nối tên này vào đường dẫn thư mục Startup, tạo thành một đường dẫn đích hoàn chỉnh.
4. Thực thi lệnh sao chép chính nó từ vị trí khởi chạy ban đầu đến đường dẫn đích mới trong thư mục Startup thông qua API `CopyFileA`.

Mẫu phân tích là một chương trình được thiết kế nhằm mục đích thiết lập Persistence trên hệ thống. Bằng cách tự động đặt một bản sao vào thư mục Startup của Windows, chương trình đảm bảo sẽ được hệ điều hành tự động kích hoạt mỗi khi máy tính khởi động.